PRADITA University

IT40813 · IT Governance, Risk & Compliance

Risiko Pihak Ketiga dan Cloud

Pertemuan 09

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Rantai Pasok dan Konsentrasi
3. Siklus Hidup
4. Klausul Kontrak
5. Cloud
6. Berbagi Data dan DPIA
7. Aktivitas, Ringkasan, dan Latihan

PRADITA University

Kontrak sudah selesai. Mengapa akun vendor masih membaca 1.240 rekam?

Tujuan Pembelajaran

- Menyusun siklus hidup manajemen risiko pihak ketiga, mulai dari uji tuntas sampai pemutusan kontrak.
- Memetakan pembagian tanggung jawab keamanan antara organisasi dan penyedia cloud.
- Menyusun penilaian dampak pelindungan data pribadi untuk alur berbagi data dengan mitra.

Masalah: Kontrak Tidak Mengakhiri Risiko

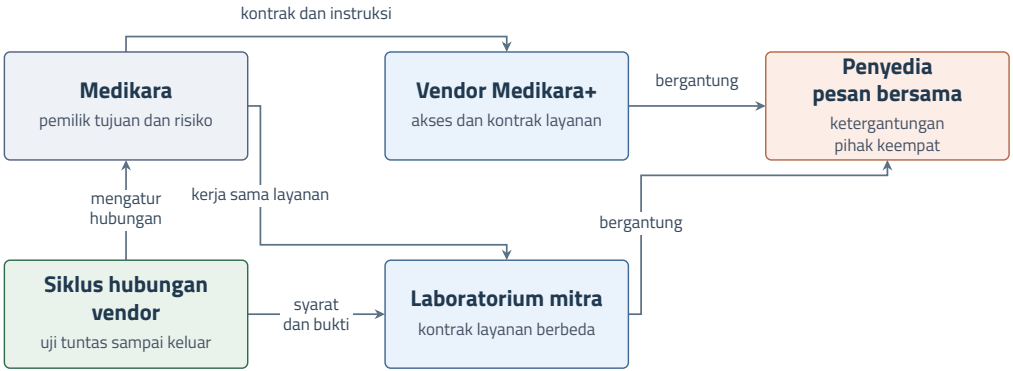
PRADITA University

- Data latihan Bab 7: kontrak pekerjaan selesai, akun dukungan tetap aktif.
- Selama 8 malam, 155 panggilan per malam membaca 1.240 rekam pada dua rumah sakit.
- Medikara baru tahu pada hari ke-11, lewat keluhan pasien.
- Vendor, cloud, dan mitra data membawa ketergantungan berbeda.
- Hasil kerja untuk C3: kerangka pihak ketiga, matriks cloud, dan DPIA.

Diagram Konsep Bab 9

PRADITA University

Risiko konsentrasi tersembunyi di balik beberapa vendor



Dua vendor dapat memiliki satu titik kegagalan bersama. Kontrak dan sertifikat penyedia tidak menghapus tanggung jawab pelanggan.

Pihak Ketiga dan Pihak Keempat

PRADITA University

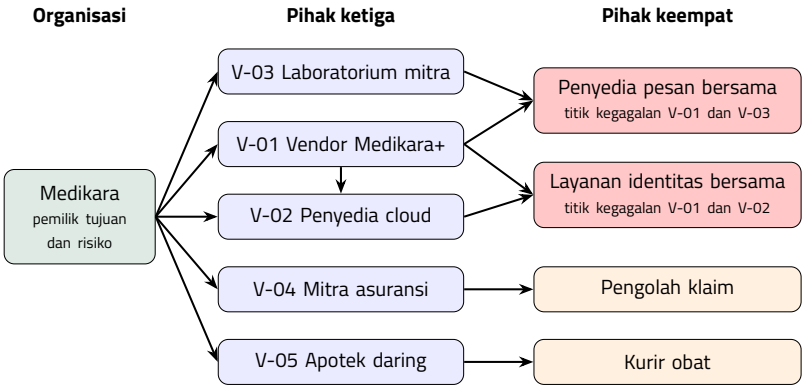
- Pihak ketiga: vendor aplikasi, penyedia cloud, mitra data, dan layanan pendukung.
- Pihak keempat: pemasok yang dipakai pihak ketiga.
- NIST CSF 2.0 menyebut ekosistem pasok dengan beberapa lapis alih daya.
- Analogi kantin: dua pedagang dari satu gudang tidak memberi keragaman pasokan.
- Jumlah kontrak tidak sama dengan jumlah sumber daya yang independen.

Menghitung Konsentrasi (Misalkan)

Keadaan	Hitungan	Gangguan bersamaan
Dua penyedia terpisah	0,5% kali 0,5% kali 8.760 jam	Sekitar 13 menit per tahun
Satu penyedia pesan	0,5% kali 8.760 jam	43,8 jam per tahun

- Selisihnya 200 kali lipat. Register Bab 5 mencatatnya sebagai R-08, skor $2 \times 4 = 8$.
- Pengingat 336.000 janji temu ikut terganggu sekitar 0,5 persen, atau 1.680 janji temu.
- 144 uji pemulihan dapat lulus tanpa menjawab cadangan di akun yang sama.

Peta Ketergantungan (Misalkan)



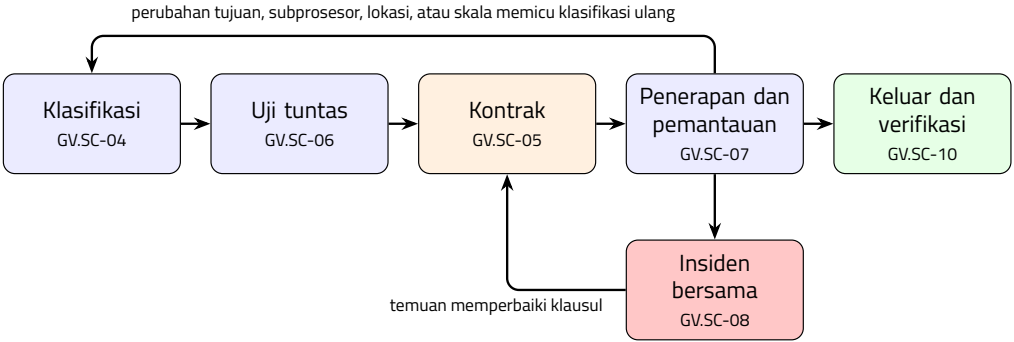
V-01 memakai 3 penyedia pendukung, sehingga Medikara perlu 3 persetujuan tertulis (Pasal 51 ayat (5) UU PDP).

Membaca Tiga Sumber

Sumber	Angka	Batas pembacaan
Survei AHA, Change Healthcare	Hampir 1.000 rumah sakit: 94% dampak keuangan, 83% arus kas, 74% pelayanan langsung	Laporan mandiri, dibuat asosiasi rumah sakit
NHS England London, Synnovis	Janji rawat jalan dan tindakan elektif ditunda pada dua *trust*; angka rinci tidak dikutip	Data manajemen yang belum diverifikasi
DBIR 2026 lewat WaterISAC	Pihak ketiga terlibat pada 48% pelanggaran	Bagian dari pelanggaran, bukan peluang

Angka global tidak disalin menjadi peluang Medikara. Bab 5 tetap memakai peluang R-01 sebesar 0,2 per tahun.

Siklus Kendali Pihak Ketiga



Analogi sewa kendaraan: periksa saat menerima, catat aturan, pantau gangguan, periksa saat mengembalikan.

Tahap, Hasil, dan Bukti (Misalkan)

Tahap	Hasil	Bukti pada Medikara
Klasifikasi	GV.SC-04	Register pemasok dengan skor
Uji tuntas	GV.SC-06	Kuesioner beserta bukti dan cakupan
Kontrak	GV.SC-05	11 dari 11 butir; klausul K-05
Penerapan dan pemantauan	GV.SC-07	60 dari 60 catatan AC-01; tinjauan triwulanan
Insiden bersama	GV.SC-08	2 latihan per tahun; laporan 12 jam
Keluar	GV.SC-10	Hasil uji ekspor dan bukti penghapusan

Hanya GV.SC-07 yang masuk profil target Bab 8. Lima baris lain menjadi pertanyaan kerja.

Klasifikasi Enam Hubungan (Misalkan)

ID	Hubungan	Data	Kritis	Ganti	Skor	Tingkat
V-01	Vendor Medikara+	3	3	3	9	Terperinci
V-02	Penyedia cloud	3	3	2	8	Terperinci
V-03	Laboratorium mitra	3	3	2	8	Terperinci
V-04	Mitra asuransi	3	2	2	7	Terperinci
V-05	Apotek daring	2	2	1	5	Menengah
V-06	Penyedia cetak materi	0	0	1	1	Dasar

Skor 7 sampai 9 terperinci, 4 sampai 6 menengah, 0 sampai 3 dasar. Skala ini rancangan pembelajaran, bukan rumus standar.

Mengapa Pemeriksaan Dibuat Bertingkat

PRADITA University

- Analogi tamu rumah sakit: pengantar bunga mendaftar di lobi, teknisi ruang obat perlu surat tugas dan pendamping.
- Misalkan 40 hubungan: 5 terperinci, 12 menengah, 23 dasar.
- Pada 40, 16, dan 4 jam per hubungan, totalnya 484 jam, atau Rp29,04 juta.
- Bila semua diperiksa terperinci: 1.600 jam, atau Rp96 juta.
- Pembagian tingkat menghemat 1.116 jam, sekitar 70 persen.

Uji Tuntas: Dari Jawaban ke Bukti

Jenis bukti	Contoh	Yang diperiksa
1. Jawaban vendor	Kuesioner, CAIQ	Tanggal dan siapa yang menjawab
2. Dokumen vendor	Kebijakan, prosedur	Apakah dijalankan pada layanan itu
3. Laporan independen	Sertifikat, laporan SOC 2	Cakupan, periode, pengecualian
4. Uji bersama	Uji ekspor, latihan insiden	Hasil, kekurangan, uji ulang

- Misalkan 10 dari 10 jawaban ya, tetapi hanya 7 punya bukti dalam cakupan: 70 persen.
- Skor eksternal dari informasi publik tidak sepenuhnya menyatu (Keskin dan rekan, 2021).

Pemantauan Sepanjang Hubungan (Misalkan)

Indikator	Ambang	Tindakan bila terlewati
Akun vendor tanpa pemilik	0 akun (Bab 5)	Bekukan akun dan catat penyimpangan
Catatan peninjauan AC-01	60 dari 60 per tahun	Eskalasi ke kepala TI
Laporan dugaan insiden	12 jam (K-05)	Catat pelanggaran dan tagih perbaikan
Latihan insiden bersama	2 per tahun	Masuk temuan Paket C
Pemberitahuan subprosesor	30 hari sebelumnya	Tunda perubahan atau putuskan risiko sisa
Uji ekspor	1 per tahun	Tinjau ulang skor R-10

Tinjauan paralel Bab 8 memakan 10 hari kerja, sekitar 14 hari kalender. Dari 30 hari, tersisa 16 hari untuk menguji layanan pengganti.

Strategi Keluar Perlu Diuji

Opsi R-10	Biaya sekali	Harapan setelahnya	Turun per tahun	Balik modal
Uji ekspor dan pendampingan	Rp60 juta	0,1 kali Rp300 juta, atau Rp30 juta	Rp50 juta	1,2 tahun
Ganti vendor segera	Rp300 juta	0,05 kali Rp800 juta, atau Rp40 juta	Rp40 juta	7,5 tahun

- Awal: peluang 0,1 dan kerugian Rp800 juta, harapan Rp80 juta per tahun.
- Uji 10.000 rekam sintetis: 96 persen terbaca mesin. Sisa 13.440 rekam per tahun memakan 1.120 jam, atau Rp67,2 juta.
- Vendor baru dapat memakai subpenyedia yang sama, sehingga R-08 tidak berubah.

Kasus Medikara: Dua Prioritas

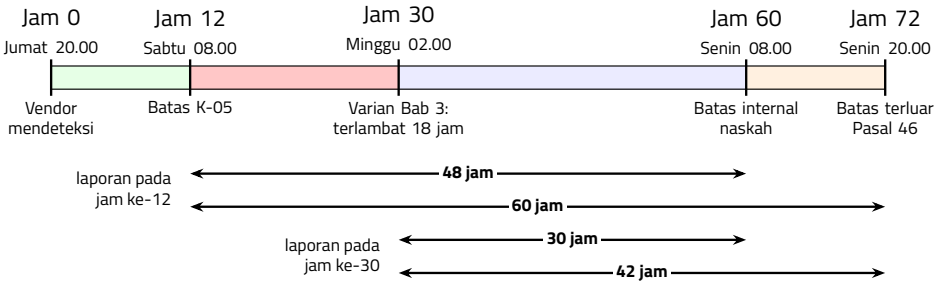
PRADITA University

- Empat dari lima hubungan target masuk tingkat terperinci.
- V-01 terpilih dengan skor 9. V-02 dan V-03 sama-sama 8.
- Pemutus tambahan: jumlah layanan yang berhenti. V-02 menampung seluruh platform target.
- Bab 8 menganggarkan Rp120 juta per tahun untuk APO10 tingkat 3, sedangkan R-10 turun Rp50 juta.
- Selisihnya dibenarkan oleh K-05 yang tidak memenuhi dan oleh hak pasien.

Dari Janji Menjadi Ukuran

- Kontrak menerjemahkan kendali menjadi kewajiban yang dapat ditagih.
- Analogi pengiriman: “barang dijaga” belum menjelaskan siapa menerima dan kapan terlambat.
- “Secepatnya” tidak dapat ditagih. K-05 menetapkan 12 jam sejak vendor mendeteksi.
- “Menjaga kerahasiaan” tidak menjawab akun yang tetap aktif. Akun dicabut dalam 1 hari kerja.
- Angka 12 jam pilihan kontrak, bukan tenggat undang-undang.

Klausul 12 Jam pada Garis Waktu (Misalkan)



Mengandaikan kegagalan dan penemuan bersamaan. Pasal 46 ayat (1) tidak memakai frasa sejak diketahui secara eksplisit, sehingga fungsi hukum menetapkan titik mulainya.

Sembilan Pokok Klausul: Akses dan Insiden

PRADITA University

Pokok	Ukuran penerimaan	Bukti
Instruksi dan batas tujuan	Tujuan tertulis; perubahan lewat persetujuan	Daftar instruksi berversi
Pengguna dan peninjauan akses	Pemilik dan tanggal berakhir; cabut dalam 1 hari kerja	120 dari 120 akun cocok; AC-01
Subprosesor	Persetujuan tertulis; pemberitahuan 30 hari	Daftar penerima dan persetujuan
Lokasi dan akses dukungan	Di dalam wilayah Indonesia, kecuali izin sesuai Pasal 972	Inventaris lokasi data, cadangan, dan akses
Laporan dugaan insiden	Laporan awal 12 jam; 2 latihan per tahun	Kronologi dan hasil latihan

Sembilan Pokok Klausul: Bukti dan Keluar

Pokok	Ukuran penerimaan	Bukti
Catatan aktivitas	Per orang; disimpan 90 hari	Uji telusur satu rekam
Pemeriksaan dan asurans	Bukti dapat ditinjau sesuai cakupan	Laporan, pengecualian, dan tindak lanjut
Ekspor dan biaya keluar	Format dan tenggat disepakati; ekspor lengkap	Hasil uji ekspor tahunan
Penghapusan dan cadangan	Terverifikasi, termasuk salinan cadangan	Berita acara penghapusan

Ganti rugi dapat memindahkan biaya Rp23,7 juta. Kewajiban Pasal 46 tetap pada Medikara, dan kepercayaan pasien tidak berpindah lewat kontrak.

Enam dari Sebelas Butir

PRADITA University

- Salinan pihak ketiga PP 33/2026 Pasal 14 memuat 11 butir. Naskah resmi belum diperoleh, jadi dipakai sebagai daftar periksa.
- Bab 7: perjanjian memuat 6 dari 11 butir. Bab 8 menargetkan 11 dari 11.
- Lima pokok tawar ulang (penafsiran bab): instruksi, daftar akun dan subprosesor, pencabutan akses, pengawasan dan audit, pengembalian dan penghapusan.
- Laporan 12 jam sudah ada pada K-05: jawabannya latihan. Waktu pulih kontrak (V-01 24 jam, layanan identitas 8 jam) ditawar tersendiri pada Bab 10.
- K-12 berjalan sebaliknya: Medikara melapor ke mitra asuransi dalam 1 jam, 2 dari 12 tepat waktu.

Kasus Medikara: Klausul untuk Insiden 2025

Klausul	Ukuran	Akibat pada kronologi
Pencabutan akun	1 hari kerja setelah penugasan selesai	Akun tidak aktif pada malam pertama
Pemantauan dan laporan	Laporan dugaan insiden 12 jam	Deteksi malam pertama: 155 rekam, turun 87,5 persen. Setelah dua malam: 310, turun 75 persen
Catatan aktivitas	Per orang; 90 hari	Seluruh 8 malam tertelusur, bukan hanya 620 rekam

Klausul tidak menjawab bahwa Medikara tahu lewat keluhan pasien. Tinjauan catatan aktivitas di sisi Medikara masuk Paket D.

Tanggung Jawab Bersama

- NIST SP 800-145: lima karakteristik, tiga model layanan, empat model penyebaran.
- IaaS, PaaS, dan SaaS memindahkan lapisan operasi yang berbeda.
- AWS: *security of the cloud* milik penyedia, *security in the cloud* milik pelanggan.
- Analogi sewa tempat: pengelola menjaga gedung, penyewa mengatur kunci dan dokumen.
- Pasal 51 ayat (3) UU PDP: pemrosesan oleh prosesor termasuk tanggung jawab pengendali.

Pembagian Lapisan Menurut Panduan Microsoft

Lapisan	IaaS	PaaS	SaaS
Data pelanggan	Pelanggan	Pelanggan	Pelanggan
Konfigurasi dan pengaturan	Pelanggan	Pelanggan	Pelanggan
Identitas dan pengguna	Pelanggan	Pelanggan	Pelanggan
Perangkat klien	Pelanggan	Pelanggan	Bersama
Aplikasi	Pelanggan	Bersama	Bersama
Kendali jaringan	Pelanggan	Bersama	Penyedia
Sistem operasi	Pelanggan	Penyedia	Penyedia
Host fisik	Penyedia	Penyedia	Penyedia
Jaringan fisik	Penyedia	Penyedia	Penyedia
Pusat data fisik	Penyedia	Penyedia	Penyedia

Panduan itu ilustratif dan tidak mengubah perjanjian. Pelanggan memegang penuh 7, 4, dan 3 dari 10 lapisan. Pada SaaS, 5 dari 10 lapisan masih memerlukan kerja pelanggan.

Dua Contoh: Pekerjaan Tidak Hilang

- Misalkan IaaS untuk 40 server virtual, pembaruan 1 jam per server per bulan.
- Bebannya 480 jam per tahun, atau Rp28,8 juta, sekitar 4,2 persen kapasitas tim platform 6 orang.
- Misalkan SaaS: penyedia mengoperasikan aplikasi, Medikara tetap mengatur pengguna.
- Peninjauan 120 akun menghasilkan 60 catatan per tahun, dan itu pekerjaan Medikara.
- Isi matriks dari rancangan IT40713, bukan dari nama model saja.

Empat Bentuk Bukti Penyedia

Bentuk	Yang dijawab	Yang harus dibaca
CAIQ	Apa yang dinyatakan penyedia	Versi, tanggal, layanan, dan bukti tiap jawaban ya
Sertifikat ISO/IEC 27001	Apakah sistem manajemen memenuhi persyaratan pada ruang lingkup itu	Ruang lingkup, lokasi, masa berlaku, dan penerbit
SOC 2 Type 1	Apakah kendali dirancang dan diterapkan pada satu tanggal	Tanggal, kategori, dan uraian sistem
SOC 2 Type 2	Apakah kendali bekerja selama satu periode	Periode, pengecualian, kontrol pelengkap

CCM versi 4.1 memuat 197 objektif kontrol dalam 17 domain. Jawaban ya tetap klaim yang perlu dibuktikan.

Membaca Bukti: Dua Contoh

PRADITA University

- Sertifikat vendor berlaku 14 bulan, tetapi cakupannya hanya pengembangan aplikasi. Akun dukungan tidak termasuk.
- Laporan SOC 2 Type 2 mencakup Januari sampai Juni 2026. Dibaca 1 November, empat bulan belum tercakup.
- Pengujian mencatat 3 pengecualian dari 25 sampel pencabutan akses: 12 persen.
- Dari 14 kontrol pelengkap pengguna, Medikara baru menjalankan 9.
- Lima sisanya pekerjaan Medikara, bukan pekerjaan penyedia.

Lokasi Data dan Akses Dukungan

Aspek	Pertanyaan	Dasar penelusuran
Pusat data	Di mana data aktif disimpan?	PP 28/2024 Pasal 966 ayat (2)
Cadangan	Di mana salinan cadangan berada?	Pasal 966; Permenkes 24/2022 Pasal 20
Jasa pihak lain	Apakah data tetap dikendalikan penuh?	Pasal 966 ayat (5); Permenkes Pasal 22
Akses dukungan	Dari negara mana staf dapat melihat data?	Pasal 971 ayat (2) dan Pasal 972
Transfer	Apakah ada tujuan spesifik dan izin?	Pasal 972; UU PDP Pasal 56

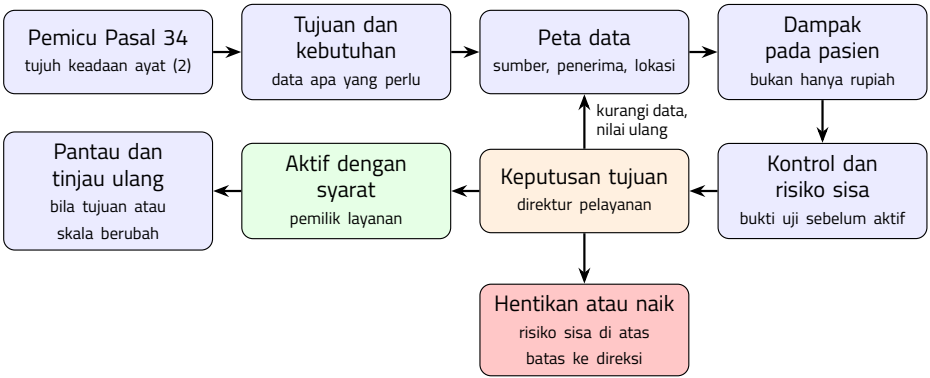
- Tawaran Rp420 juta, hemat Rp180 juta, berhenti pada Pasal 966 ayat (2).
- 4 staf luar negeri, 300 tiket per bulan: dukungan dalam negeri Rp300 juta per tahun lebih mahal.

DPIA Berfokus pada Dampak Pasien

PRADITA University

- Pasal 34 UU PDP: DPIA wajib bila pemrosesan berpotensi risiko tinggi.
- Alur klaim 72.000 per tahun menyentuh data spesifik, skala besar, dan penggabungan data.
- Analogi jalan perumahan: jalan baru mengubah keselamatan penghuni, bukan hanya pendapatan.
- Misalkan asuransi meminta riwayat 10.000 pasien untuk kepesertaan.
- Nilai apakah status minimum memenuhi tujuan tanpa riwayat lengkap.

Alur DPIA (Penafsiran Bab)



Mengurangi Data Lebih Dahulu (Misalkan)

Pilihan	Rekam	Kolom	Nilai data
Riwayat lengkap	$10.000 \times 30 = 300.000$	42	12.600.000
Klaim lengkap	72.000 per tahun	42	3.024.000
Data minimum	72.000 per tahun	9	648.000

- Data minimum turun sekitar 94,9 persen dari riwayat lengkap, dan 78,6 persen dari klaim lengkap.
- Nilai data adalah ukuran paparan, bukan ukuran risiko.
- Enkripsi tidak menghapus risiko penggunaan berlebih oleh penerima sah.

Kasus Medikara: DPIA Alur Asuransi

PRADITA University

- CP-03: DPIA alur asuransi belum ada, dan Bab 8 menjadikannya syarat.
- DPIA dikerjakan 3 orang selama 3 hari, atau 72 jam, atau Rp4,32 juta.
- Mitra meminta 1 bulan untuk mengubah sistem. Klaim manual: 500 jam, atau Rp30 juta.
- Direktur pelayanan memutuskan menunggu, dan alasannya tercatat.
- Perubahan tujuan, kolom, penerima, lokasi, atau skala memicu penilaian ulang.

Aktivitas: Kerangka Pihak Ketiga dan DPIA

PRADITA University

- Klasifikasi lima hubungan, dan peta pihak keempat yang dipakai lebih dari satu hubungan.
- Pilih dua hubungan kritis untuk uji tuntas, klausul, indikator, dan strategi keluar.
- Isi matriks layanan cloud dari rancangan IT40713.
- Susun DPIA satu alur asuransi.
- Simulasikan dugaan insiden Jumat 20.00, dengan laporan sebelum Sabtu 08.00.

Peran, Luaran C3, dan Berkas

- Peran: bisnis menilai kekritisan, analis regulasi memimpin klausul dan DPIA, analis teknologi mengisi matriks, analis risiko menautkan R-01, R-08, dan R-10.
- Rubrik: klasifikasi dan bukti, kontrak dan pemantauan, kejelasan tanggung jawab, serta dampak dan risiko sisa, masing-masing 25 persen.
- Berkas ada di `sources/chapter09/`, dengan daftar pada `README.md`.
- Data pasien dan rahasia akses tidak boleh masuk folder tugas.
- Pendalaman opsional: CCM seri 4, SBOM, dan laporan uji penetrasi.

Ringkasan

- Banyak vendor dapat memiliki satu titik kegagalan bersama.
- Uji tuntas hanya awal. Kontrak, pemantauan, perubahan, dan keluar butuh pemilik serta bukti.
- Klausul 12 jam memberi 48 jam sampai batas internal, tanpa memindahkan kewajiban Pasal 46.
- Cloud membagi pekerjaan: pada SaaS, 5 dari 10 lapisan masih memerlukan kerja pelanggan.
- DPIA menilai akibat pada pasien. Mengurangi data lebih dahulu, baru menambah kontrol.

Latihan

- Latihan 1. Jelaskan mengapa sertifikat ISO/IEC 27001 milik penyedia cloud tidak memindahkan seluruh tanggung jawab keamanan kepada penyedia.
- Latihan 2. Susun tiga klausul kontrak yang dapat mencegah atau membatasi dampak insiden seperti kebocoran lewat vendor pada 2025.
- Latihan 3. Kapan alur berbagi data dengan mitra wajib didahului DPIA? Jelaskan dengan contoh.

Bacaan dan Pesan Utama

NIST SP 800-161 Rev. 1
NIST SP 800-145
ISO/IEC 27036-2:2022
CSA CCM dan CAIQ
UU 27/2022

- Hubungan mitra yang baik memungkinkan organisasi membuktikan siapa bertanggung jawab, bukti apa yang tersedia, cara keluar yang teruji, dan bagaimana risiko sisa diputuskan.